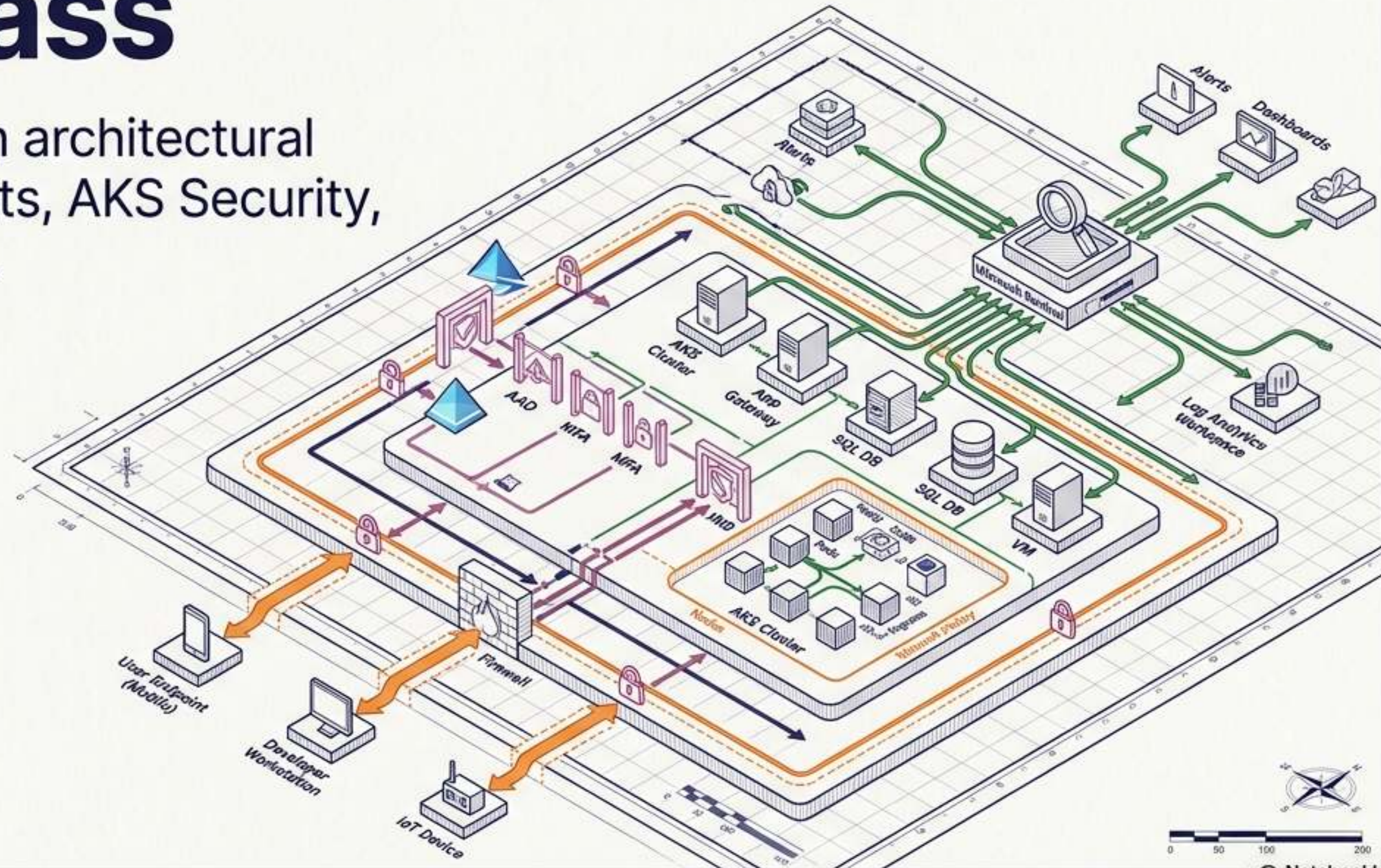


Azure Security Architecture Masterclass

Decrypting AZ-500: An architectural deep dive into Endpoints, AKS Security, and Microsoft Sentinel.



0 50 100 150 200

The Defense-in-Depth Paradigm

The Visibility: Centralized threat detection.

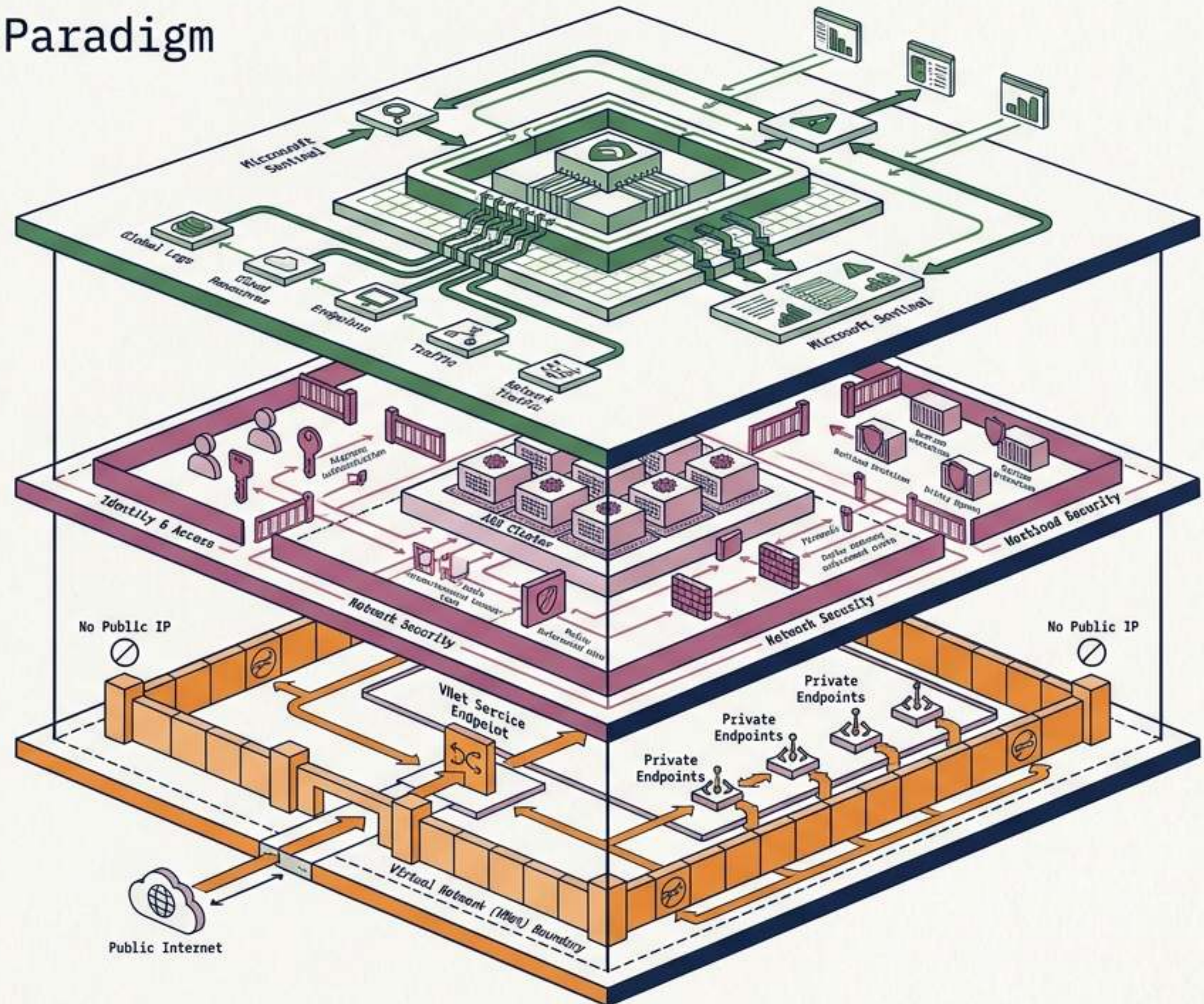
Layering Microsoft Sentinel over the top to ingest, tier, and monitor global logs.

The Execution: Hardening the application platform.

Securing the Azure Kubernetes Service (AKS) cluster across identity, network, and workload.

The Perimeter: Eliminating public exposure.

Routing traffic safely through VNet Service Endpoints and Private Endpoints.



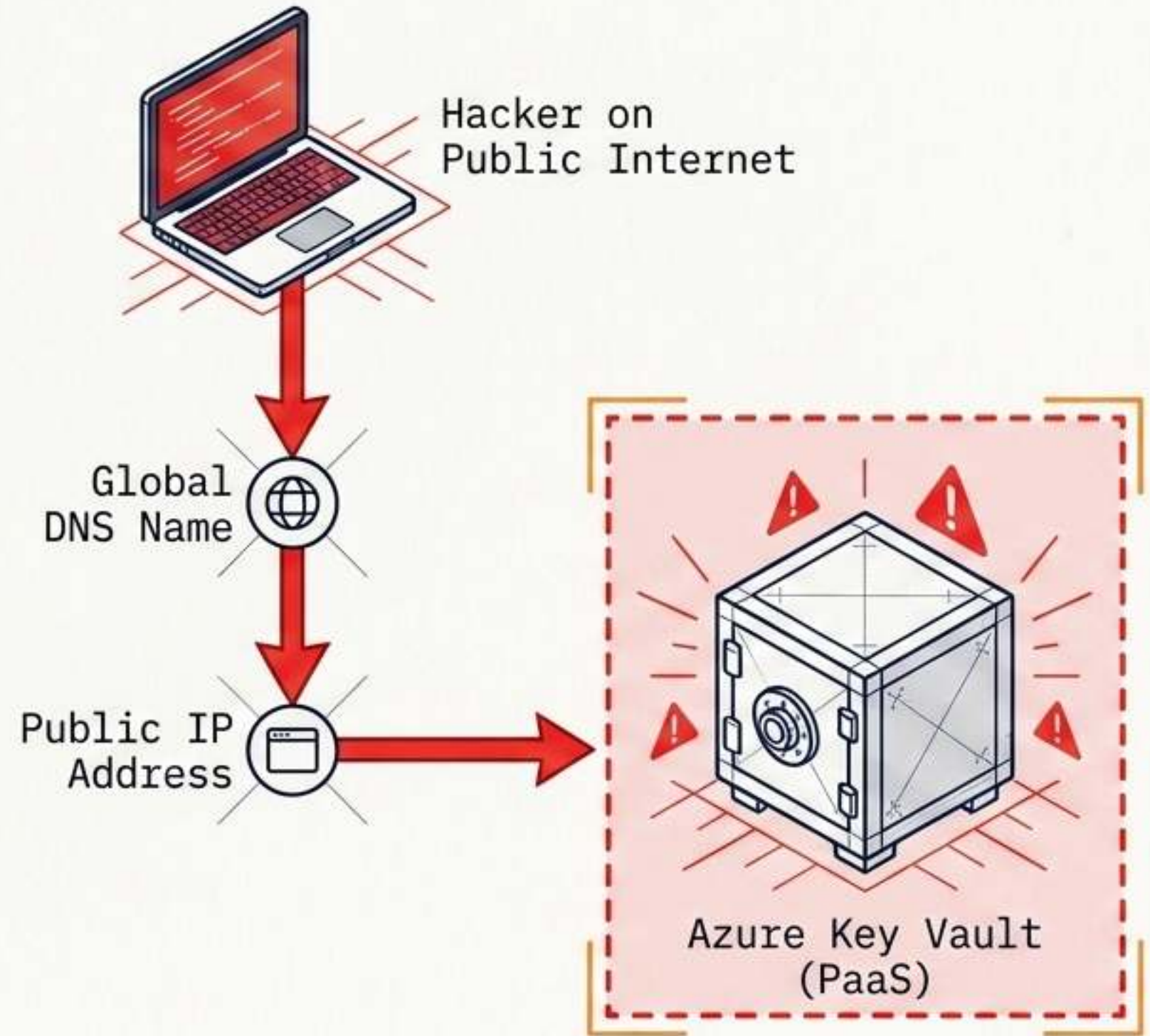
The Default PaaS Exposure Problem

Core Concept

By default, Azure PaaS resources (SQL, Storage, Key Vault) have a public, internet-resolvable fully qualified domain name (FQDN).

The Identity Trap

Microsoft Entra ID answers "Who are you?", but public endpoints mean attackers can try stolen credentials from anywhere on the internet. A stolen token works identically inside a corporate network or on public Wi-Fi.



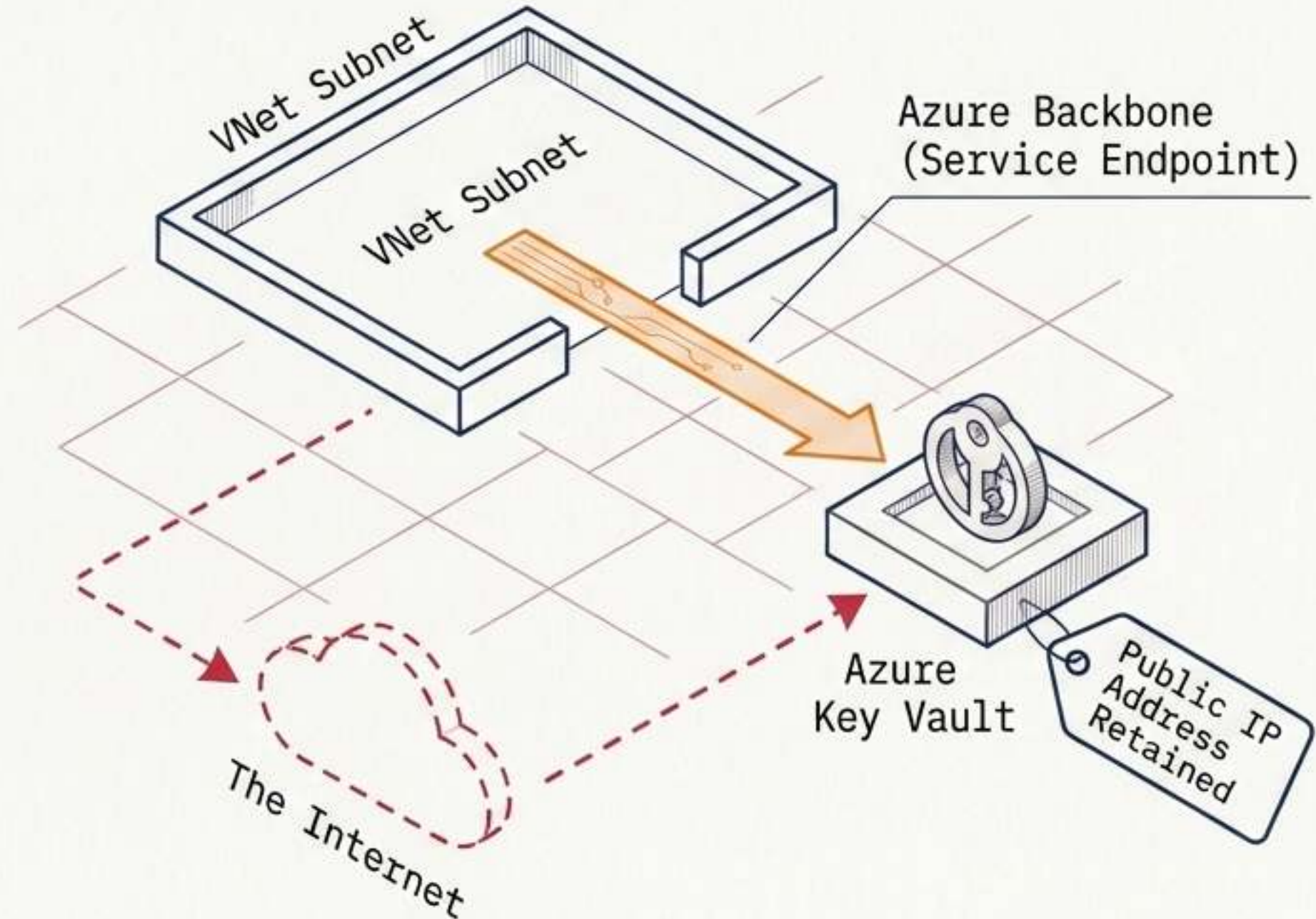
VNet Service Endpoints: The 'H0V Lane'

Mechanism

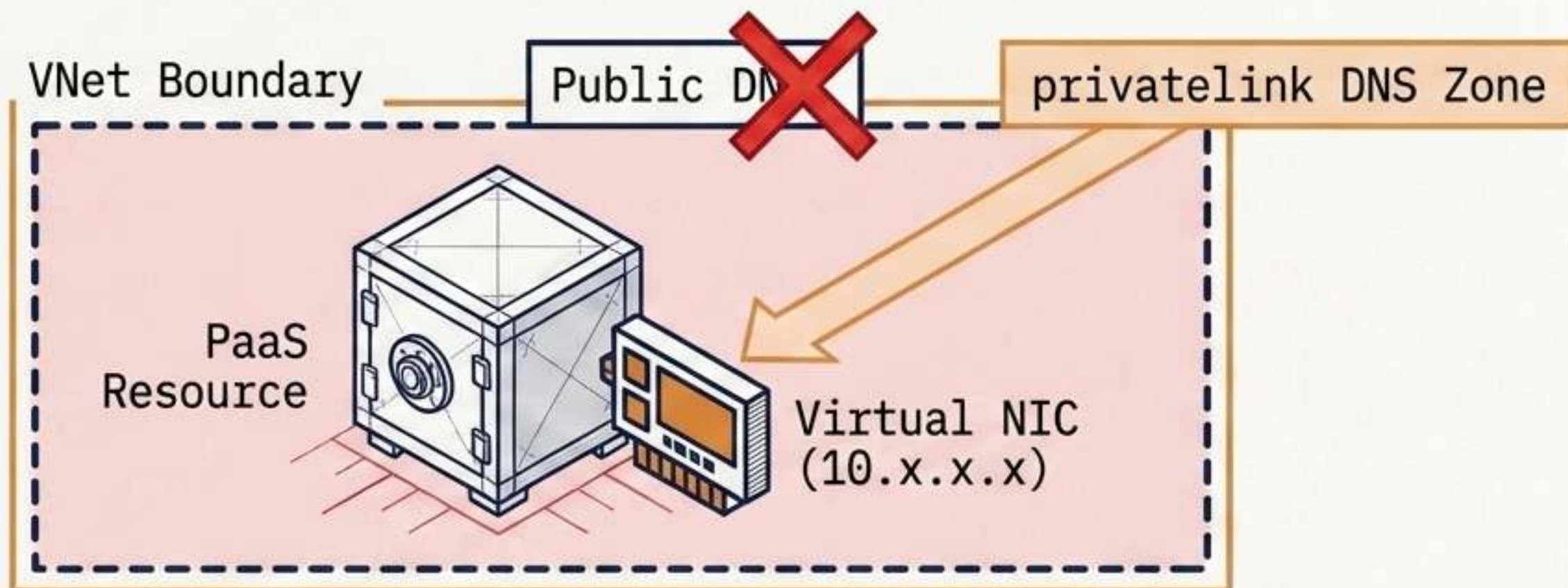
Extends a subnet's identity to the PaaS service. Traffic travels securely over the Microsoft backbone, avoiding the public internet.

The Limitation (Half-Measure)

- The public endpoint still exists.
- DNS still resolves to a public IP.
- Restricts inbound access by source network only.
- Cross-tenant exfiltration risk: A compromised VM can reach attacker-owned storage in another tenant.



Azure Private Endpoints: The 'Private Tunnel'



Mechanism

Private Link drops a dedicated Network Interface (NIC) into your subnet. The PaaS resource effectively becomes a local network resource.

The DNS Imperative

Traffic must be rerouted using a Private DNS Zone (e.g., `privatelink.vaultcore.azure.net`). Without this, traffic bypasses the private tunnel.

The Ultimate Result

The public endpoint can be completely disabled. The resource refuses outside connections, neutralizing stolen credentials.

Diagnostic Matrix: Service vs. Private Endpoints

Feature	Service Endpoints	Private Endpoints
Resource IP	Public	Private IP in VNet
DNS Changes Needed	No	Yes (privatelink zone)
Public Access Can Be Disabled	No	Yes
On-Premises Access	No, requires NAT	Yes, via VPN/ExpressRoute
Cross-Tenant Exfiltration Protection	No	Yes, scoped to specific resource
Best Fit For	Simple VNet routing optimization	Strict zero-trust regulatory compliance

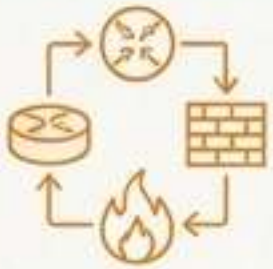
AKS Security: The Three-Layered Fortress

A Kubernetes cluster is a shared platform.
A gap in any single layer compromises the others.



Identity (Outer):

Gating who can access the cluster and what roles they hold.



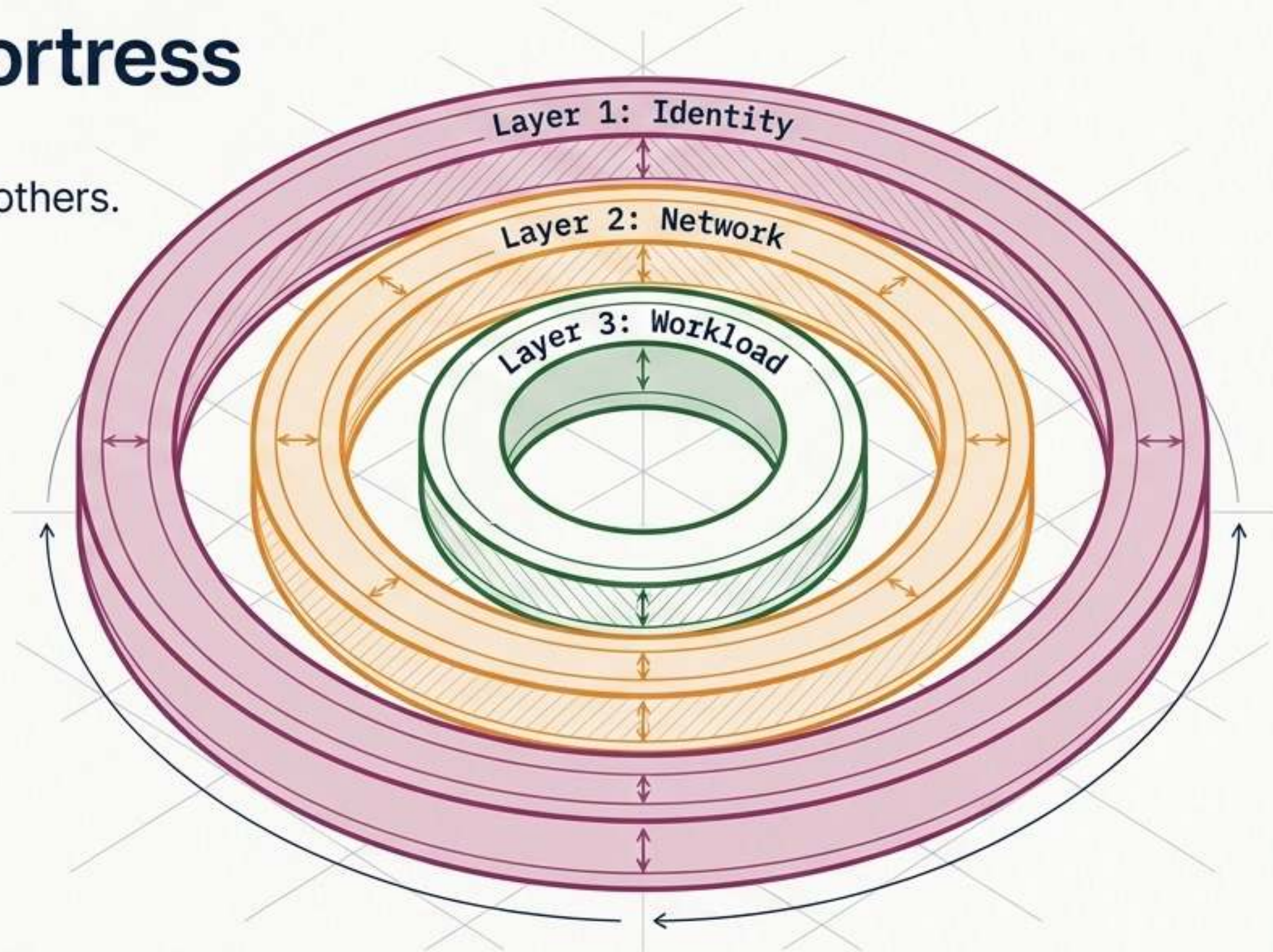
Network (Middle):

Restricting what traffic can reach the API server and move between pods.



Workload (Inner):

Constraining how the running containers behave and access external Azure services.



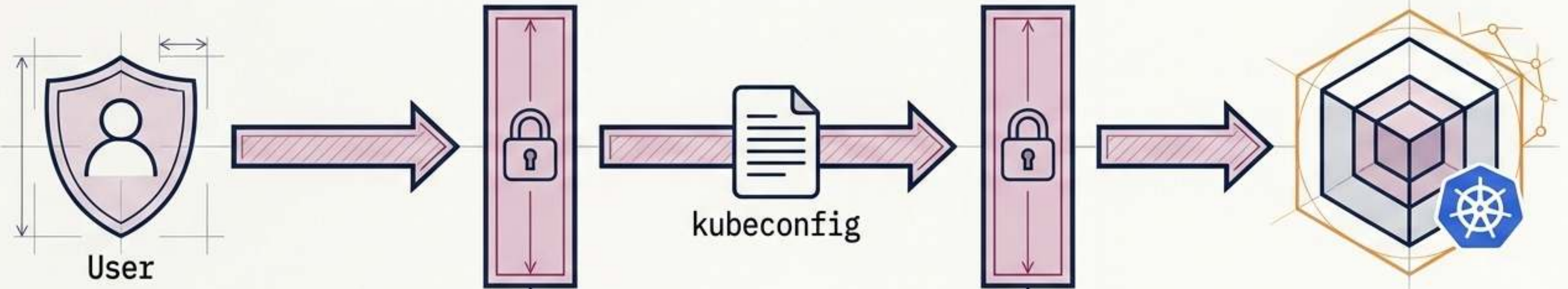
Layer 1: Cluster Identity & Access

Prerequisite: Kill the local admin account (--disable-local-accounts).

Gate 1: Azure RBAC
(Control Plane)

Gate 2: Kubernetes RBAC
(Data Plane)

Cluster
Namespace



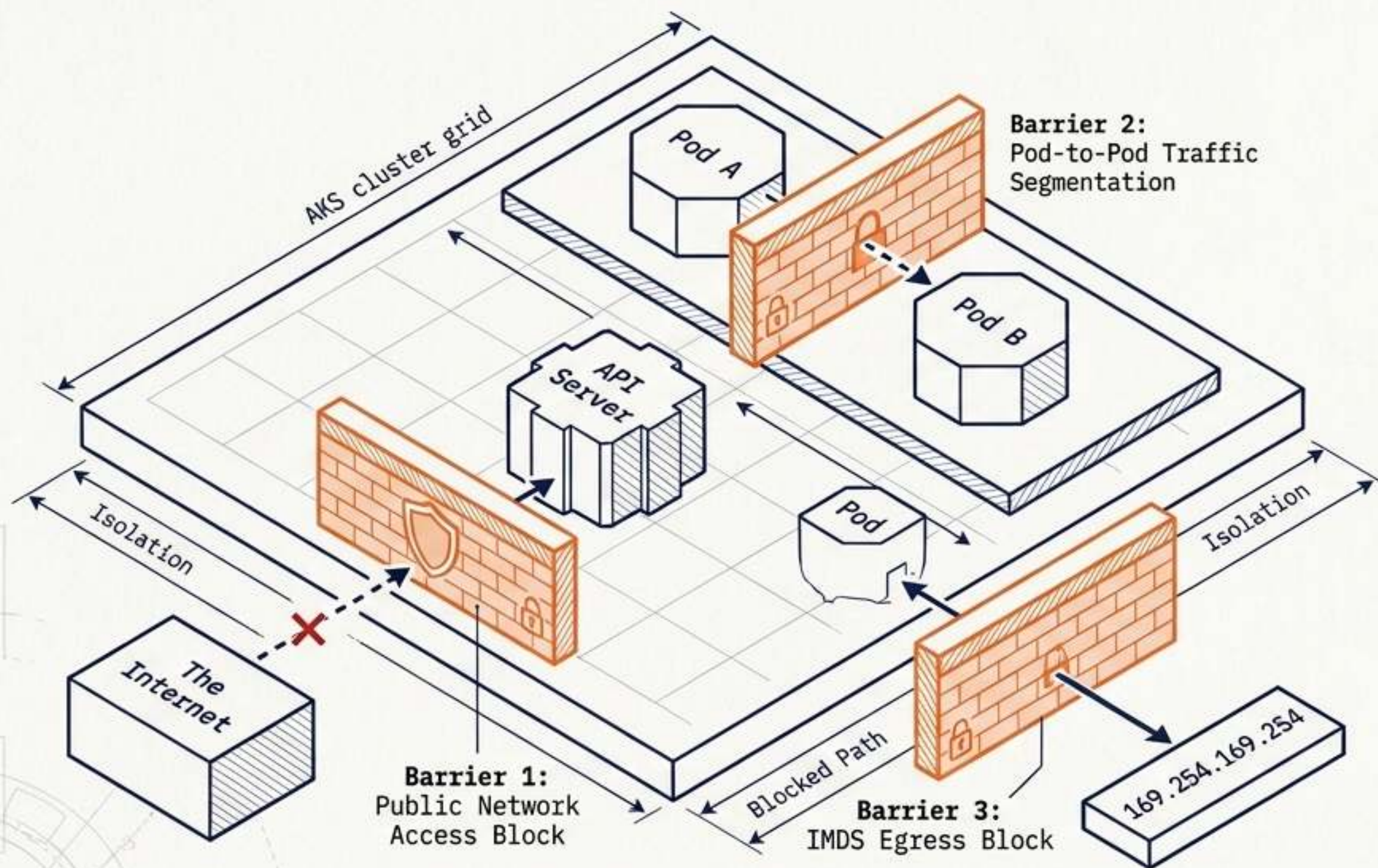
Determines WHO can download the cluster credentials.

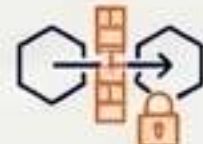
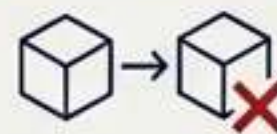
- **Cluster Admin Role:** Unrestricted kubeconfig.
- **Cluster User Role:** Authenticated but unprivileged kubeconfig.

Determines WHAT credentials can do inside the cluster.

- **Best Practice:** Bind Kubernetes RoleBindings to Microsoft Entra ID Groups, never to individual users, to automate offboarding.

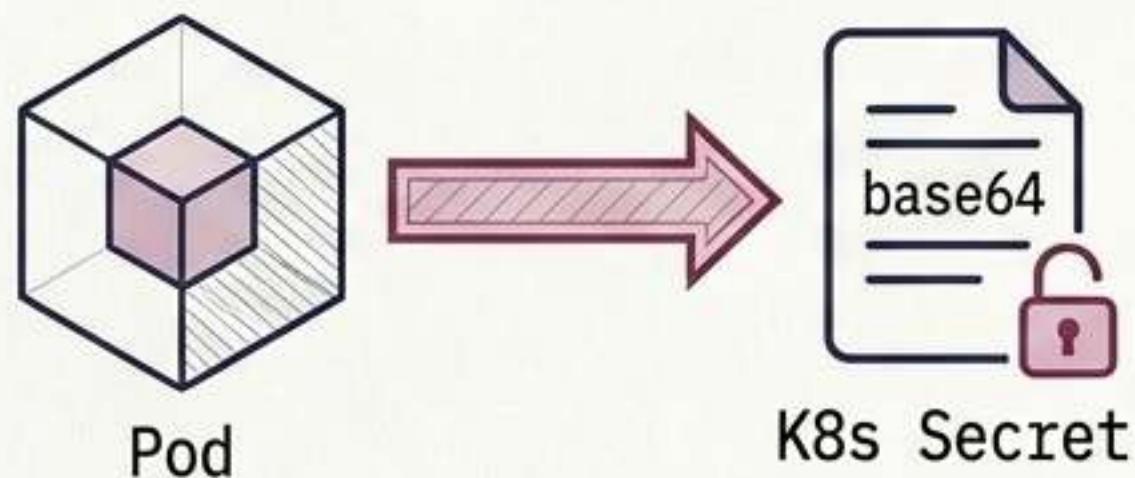
Layer 2: Network Isolation & Topology



- 1 The API Server** 
Remove the public IP entirely via Private Clusters, or restrict it using Authorized IP Ranges if public CI/CD access is required.
- 2 Pod-to-Pod Traffic** 
Use Kubernetes Network Policies. Implement default-deny namespace policies to enforce least-privilege lateral movement.
- 3 The IMDS Block** 
Egress rules must explicitly block pods from hitting 169.254.169.254/32 to prevent attackers from stealing the underlying node's managed identity.

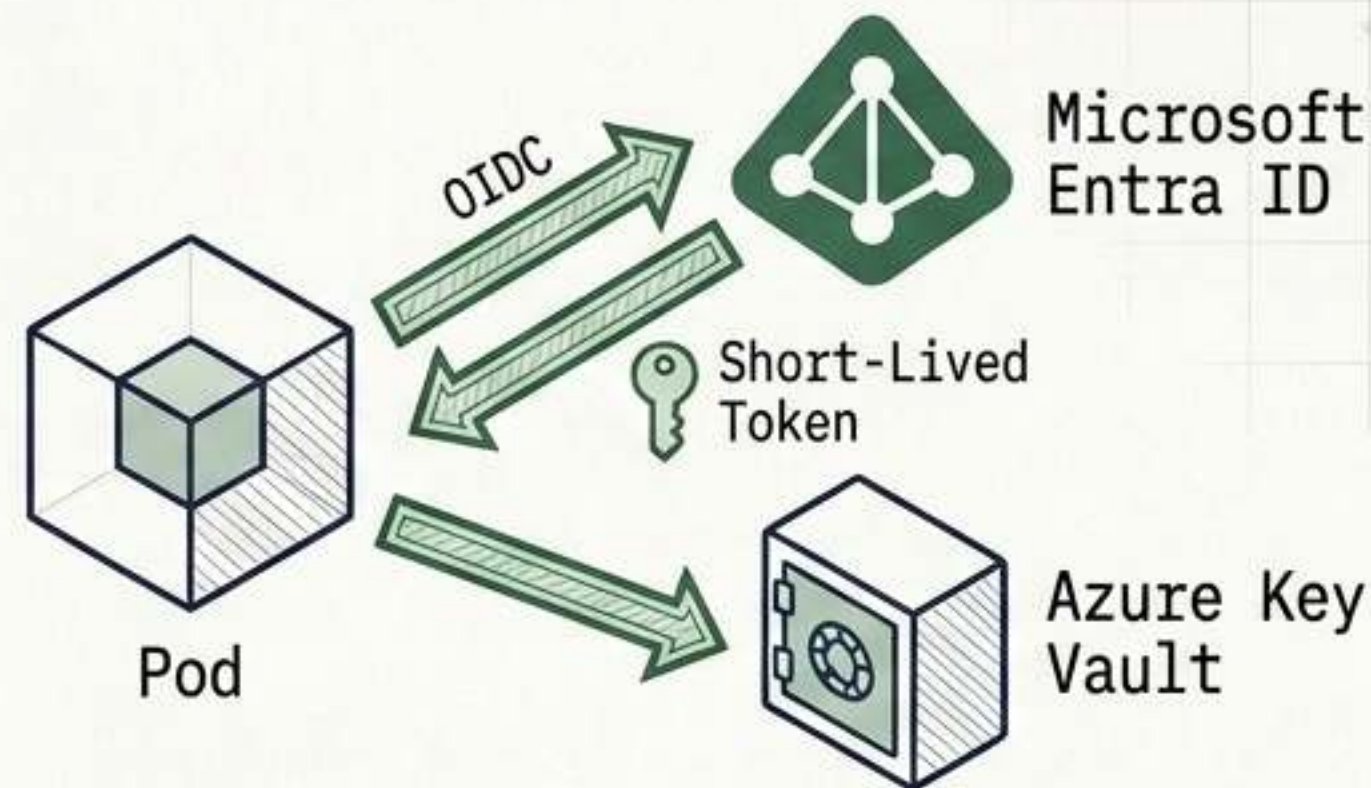
Layer 3: Workload Identity & Pod Security

BEFORE



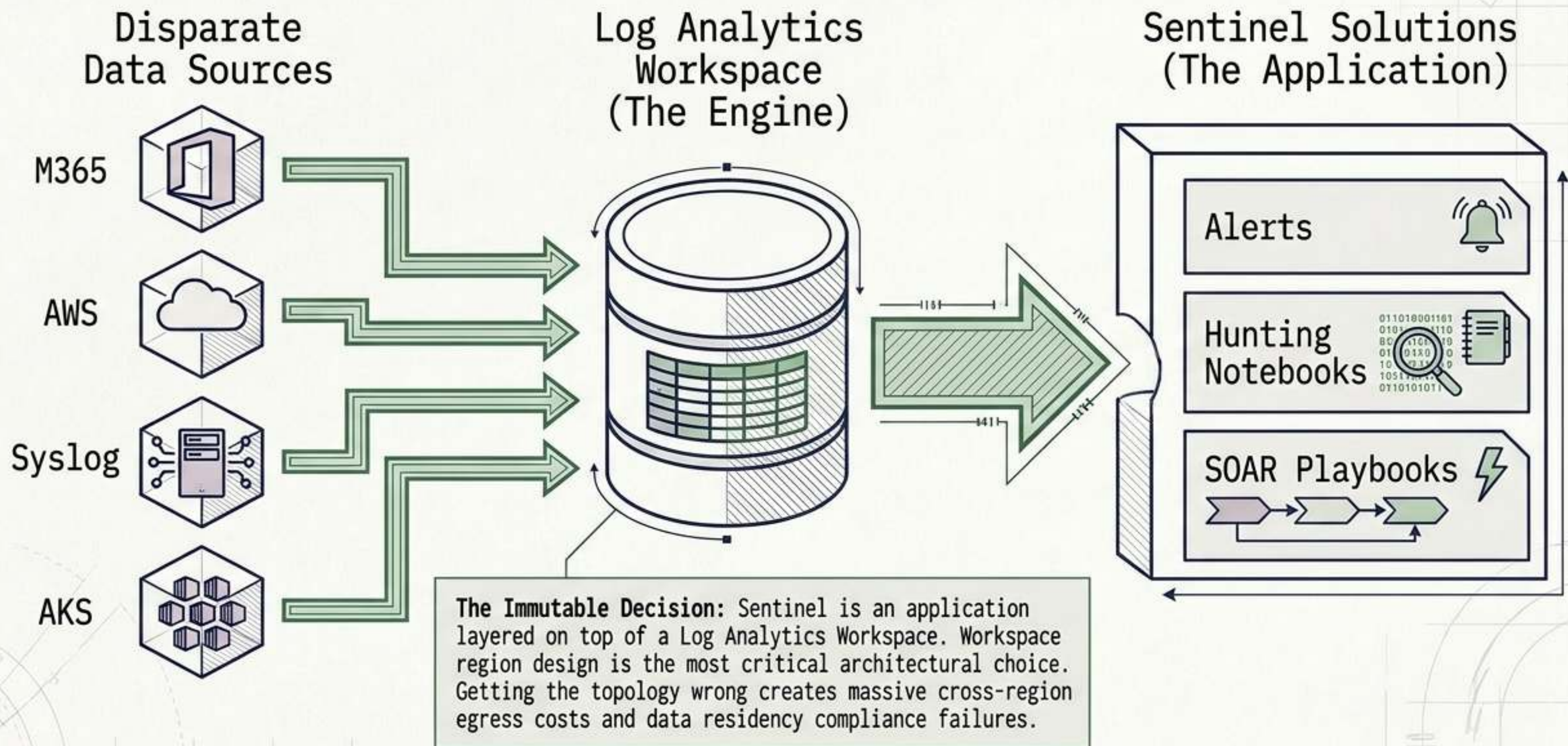
Killing Static Secrets: Kubernetes Secrets are merely base64 encoded, not encrypted. Storing database connection strings here is a major risk.

AFTER

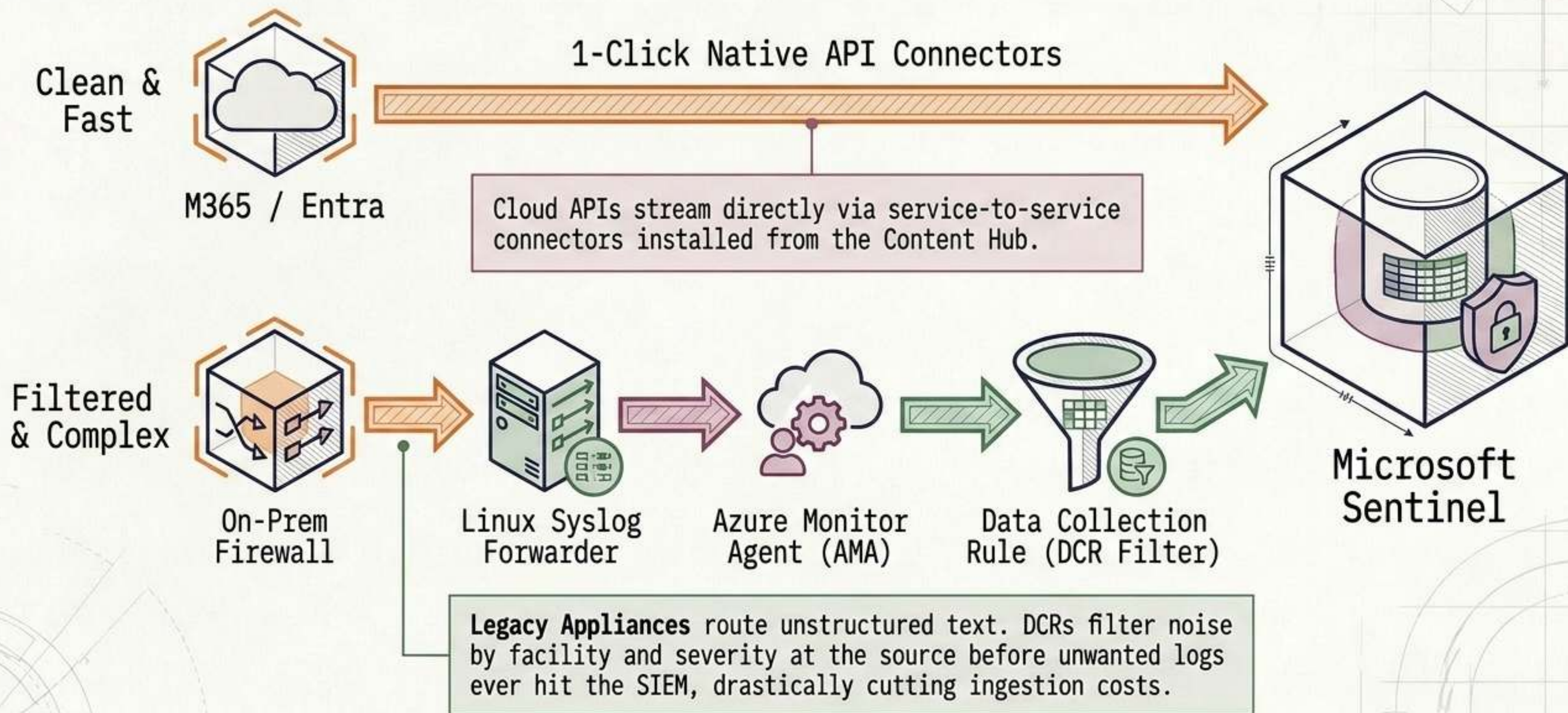


- **Microsoft Entra Workload ID:** Replaces stored credentials with federated identity. Pods authenticate using short-lived tokens via an OIDC issuer.
- **Key Vault CSI Driver:** Mounts keys directly into the pod as a volume, ensuring the secret value never touches the Kubernetes etcd datastore.
- **Pod Security Standards (PSS):** Namespace-level admission controllers that prevent containers from running as root.

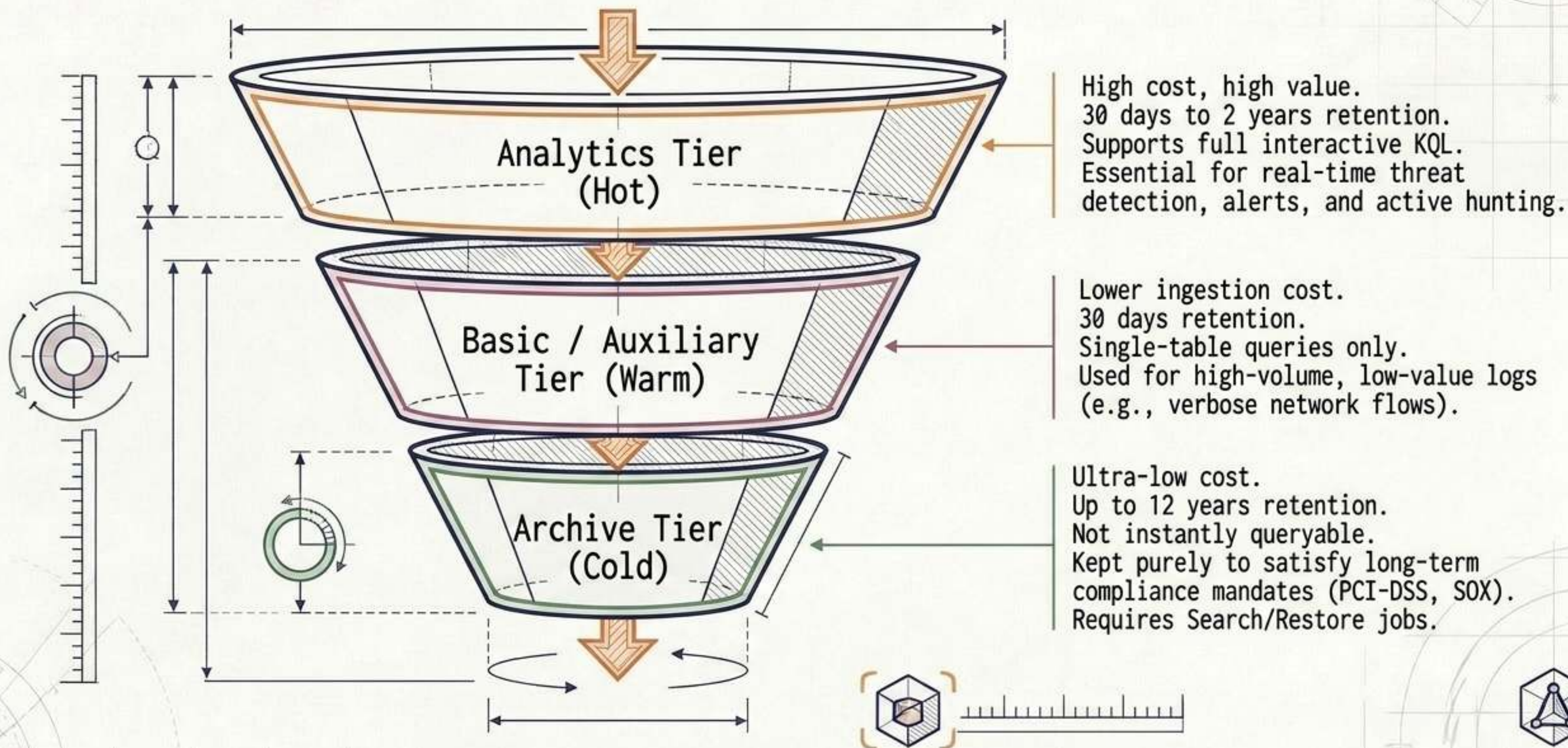
Microsoft Sentinel: The Omniscient Eye



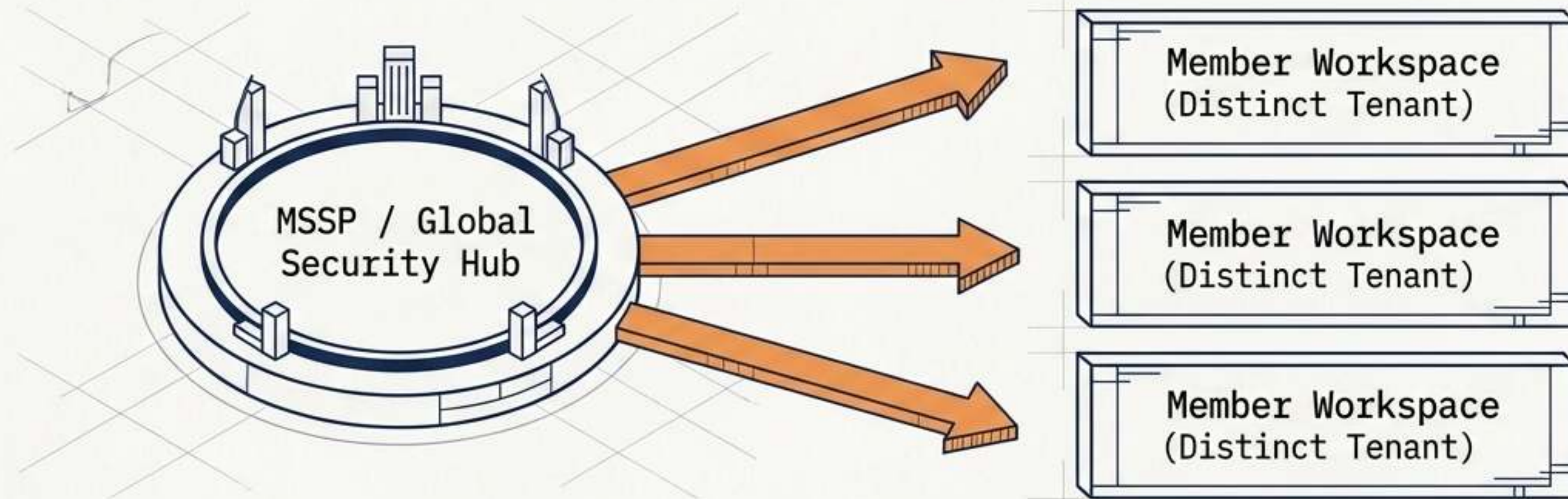
Data Ingestion: Native APIs & Syslog Pipelines



Log Tiering: The Cost-to-Performance Funnel



Multi-Tenant & Multi-Workspace Scale



Azure Lighthouse (Solving Access)

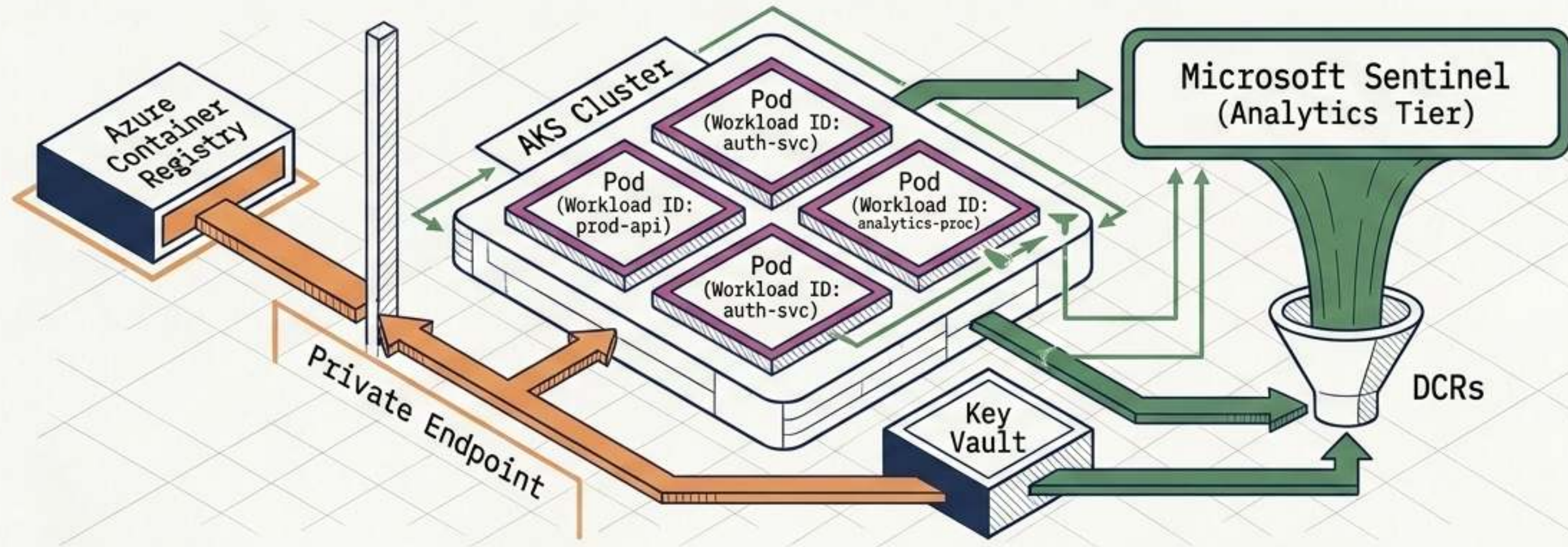
Eliminates the need for B2B guest accounts.
Grants the central security team delegated, seamless access to query and manage customer workspaces directly from their home tenant.



Workspace Manager (Solving Content)

Replaces manual configuration drift.
Allows architects to author Analytics Rules, Workbooks, and Playbooks in one central hub, and instantly push them out to hundreds of member workspaces at scale.

Synthesis: The Unified Security Topology



Network

Private Endpoints protect data transport and eliminate public attack surfaces.

Compute

AKS Identity & Workload controls protect the execution environment.

Telemetry

Sentinel monitors the entire topology, catching anomalies that evade preventative controls.

Security is not a feature you turn on; it is an architecture you design.